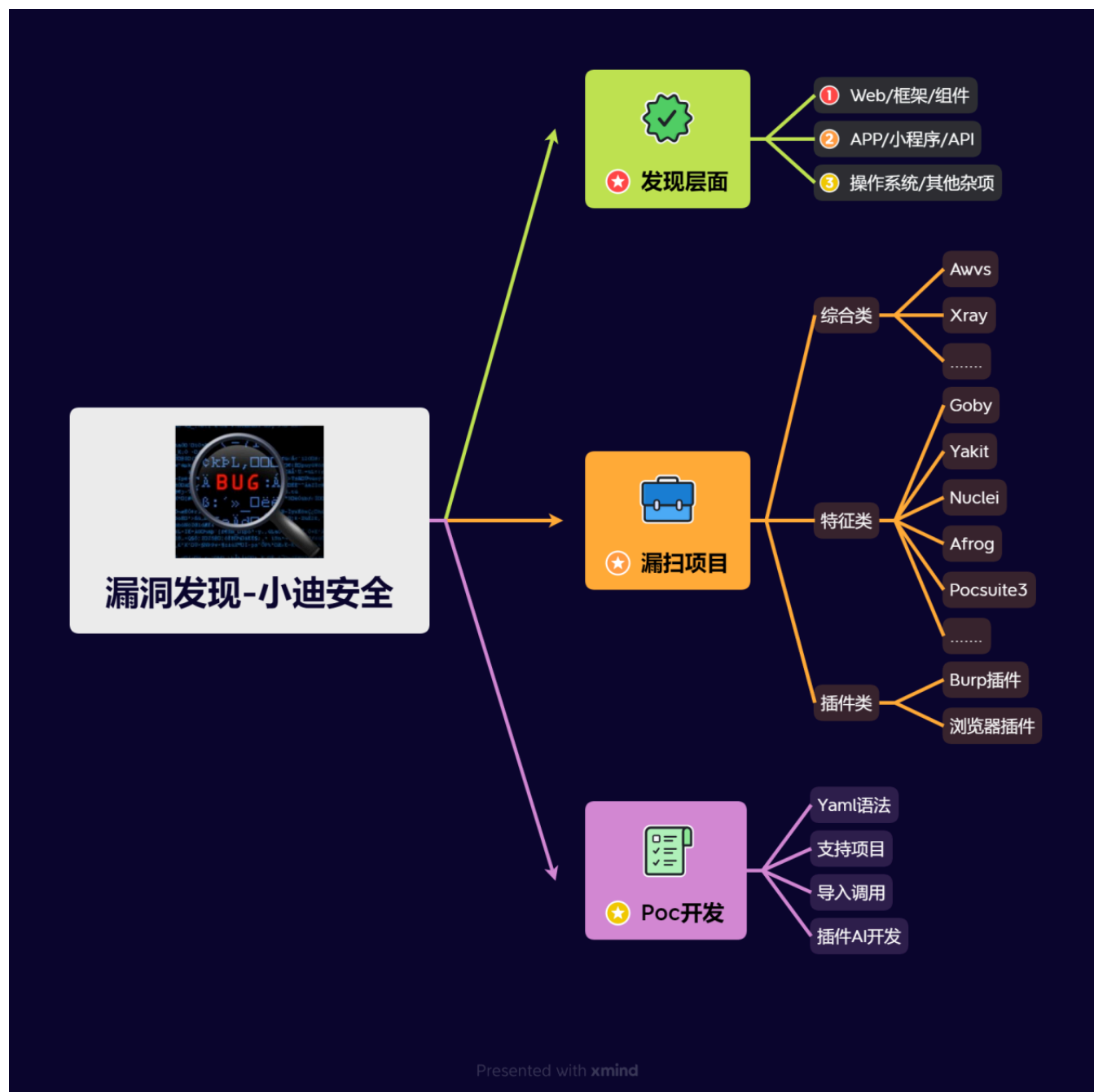


Day104 漏洞发现-漏扫项目篇&武装BURP&浏览器插件&信息收集&分析辅助&遥遥领先



1.知识点

- 1、综合类-Burp&Xray&Awvs&Goby
- 2、特征类-Afrog&Yakit&Nuclei
- 3、联动类-主动扫描&被动扫描&中转扫描

-
- 1、Nuclei-Poc开发-环境配置&编写流程

- 2、Nuclei-Poc开发-Yaml语法&匹配提取
- 3、Nuclei-Poc开发-BurpSuite一键生成插件

-
- 1、Xray&Afrog-Poc开发-环境配置&编写流程
 - 2、Xray-Poc开发-数据回显&RCE不回显&实验室
 - 3、Afrog-Poc开发-数据回显&RCE不回显&JDNI注入
-

- 1、插件类-武装BurpSuite-漏洞检测&分析辅助
- 2、插件类-武装谷歌浏览器-信息收集&情报辅助

2.详细点



- 市面上有很多漏扫系统工具脚本，课程讲到的基本都是目前主流推荐的优秀项目！
- Burpsuite, Awvs, Xray, Goby, Afrog, Yakit, Nuclei, Vulmap, Pocassist, Nessus, Pentestkit, Kunyu, Pocsuite3, 浏览器各类插件, Burpsuite插件 (HaE, ShiroScan, FastJsonScan, Log4j2Scan, Springscan, JScan等)。
-
- BurpSuite是用于攻击web 应用程序的集成平台，包含了许多工具。BurpSuite为这些工具设计了许多接口，以加快攻击应用程序的过程。所有工具都共享一个请求，并能处理对应的HTTP 消息、持久性、认证、代理、日志、警报。
-
- Acunetix一款商业的web漏洞扫描程序，它可以检查web应用程序中的漏洞，如SQL注入、跨站脚本攻击、身份验证页上的弱口令长度等。它拥有一个操作方便的图形用户界面，并且能够创建专业级的web站点安全审核报告。新版本集成了漏洞管理功能来扩展企业全面管理、优先级和控制漏洞威胁的能力。
-
- Xray是从长亭洞鉴核心引擎中提取出的社区版漏洞扫描神器，支持主动、被动多种扫描方式，自备盲打平台、可以灵活定义 POC，功能丰富，调用简单，支持windows /macOS /Linux 多种操作系统，可以满足广大安全从业者的自动化 web 漏洞探测需求。
-
- Goby是一款新的网络安全测试工具，由赵武Zwell（Pangolin、JSky、FOFA作者）打造，它能够针对一个目标企业梳理最全的攻击面信息，同时能进行高效、实战化漏洞扫描，并快速的从一个验证入口点，切换到横向。能通过智能自动化方式，帮助安全入门者熟悉靶场攻防，帮助攻防服务者、渗透人员更快的拿下目标。
-
- Nuclei是一款基于YAML语法模板的开发的定制化快速漏洞扫描器。它使用Go语言开发，具有很强的可配置性、可扩展性和易用性。 提供TCP、DNS、HTTP、FILE 等各类协议的扫描，通过强大且灵活的模板，可以使用Nuclei模拟各种安全检查。
-
- Afrog 是一款性能卓越、快速稳定、PoC 可定制的漏洞扫描（挖洞）工具，PoC 涉及 CVE、CNVD、默认口令、信息泄露、指纹识别、未授权访问、任意文件读取、命令执行等多种漏洞类型，帮助网络安全从业者快速验证并及时修复漏洞。
-
- Yakit是一款集成化单兵安全能力平台,通过函数提供各类底层安全能力，包括端口扫描、指纹识别、poc框架、shell管理、MITM劫持、强大的插件系统等。旨在打造一个覆盖渗透测试全流程的网络安全工具库。

3.演示案例

3.1 插件类-武装BurpSuite-漏洞检测&分析辅助



```
1  漏洞检测类:
2  1、Fiora
3  Nuclei提供Poc图形界面，实现快速搜索、一键运行等功能，提升体验。
4  https://github.com/bit4woo/Fiora
5
6  2、TsojanScan
7  集成的BurpSuite常见漏洞探测插件
8  https://github.com/Tsojan/TsojanScan
9
10 3、RouteVulScan
11 递归式被动检测脆弱路径的burp插件
12 https://github.com/F6JO/RouteVulScan
13
14 分析辅助类:
15 1、HaE
16 高亮标记和信息提取利器
17 https://github.com/gh0stkey/HaE
18
19 2、knife
20 数据包定位，工具调用
21 https://github.com/bit4woo/knife
22
23 3、domain_hunter_pro
24 域名提取，数据包分析，数据筛选，接口调用
25 https://github.com/bit4woo/domain_hunter_pro
26
27 4、burp_nu_te_gen
28 Nuclei模版辅助生成
29 https://github.com/fffffffff0x/burp_nu_te_gen
```

3.2 插件类-武装谷歌浏览器-信息收集&情报辅助



```
1  参考:
2  https://mp.weixin.qq.com/s/5RcG205_WGDD7b0b1sGKJA
3  https://mp.weixin.qq.com/s/KtmgH9djCHZs-kdEZK9fvQ
4  https://mp.weixin.qq.com/s/neOK5kHJyoJR6LS5yx2QGQ
5
6  部分演示:
7  -情报社区
8  -HackBar
9  -Heimdallr
```

- 10 -Wappalyzer
- 11 -Hack-Tools
- 12 -FindSomething
- 13 -SuperSearchPlus
- 14 -Penetration Testing Kit